AULA 8 – Cybersegurança e Legislação

1. AMEAÇAS, ATAQUES E PROTEÇÃO DOS DISPOSITIVOS

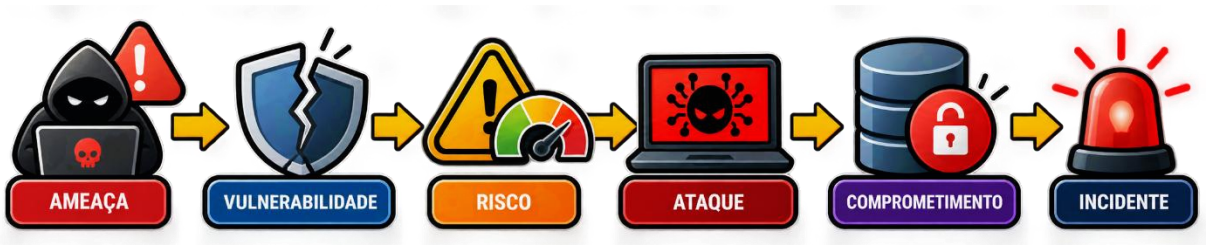
Esta unidade apresenta as principais ameaças que podem comprometer computadores, *smartphones* e outros dispositivos utilizados no ambiente institucional. O objetivo é compreender **como os ataques acontecem, quais vulnerabilidades podem ser exploradas e quais sinais podem indicar um possível comprometimento**.

Mais do que conhecer nomes de ameaças, o foco está em desenvolver uma postura de **atenção, prevenção e identificação precoce**, reduzindo as oportunidades de comprometimento dos ativos e das informações institucionais.

1.1. Ameaças, vulnerabilidades, riscos, ataques e incidentes

No ambiente digital, computadores, *smartphones*, sistemas, redes e informações estão constantemente expostos a diferentes situações que podem comprometer sua segurança. Essa exposição não significa, necessariamente, que um dispositivo esteja sendo atacado ou que tenha sido comprometido.

Para compreender como um incidente de segurança pode ocorrer, é necessário distinguir alguns conceitos fundamentais: **ameaça, vulnerabilidade, risco, ataque e incidente**. Esses conceitos estão relacionados e ajudam a explicar uma sequência bastante comum no contexto da segurança cibernética:



Cadeia Visual de Risco Cibernético

Compreender essa relação permite que o usuário deixe de enxergar a segurança apenas como uma reação a problemas já ocorridos e passe a adotar uma postura preventiva.

- **Ameaça:** Uma **ameaça** é qualquer circunstância, evento, pessoa ou ação que tenha potencial para causar dano a um ativo, sistema ou informação.

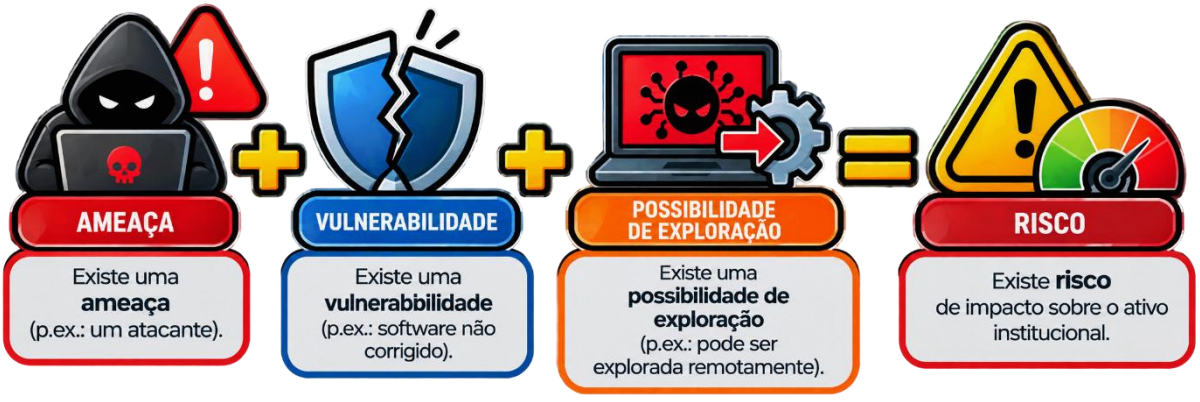
INSIGHT DO PROFESSOR

A ameaça pode existir mesmo quando nada aparentemente está acontecendo. Segurança cibernética começa justamente antes do ataque.



- **Vulnerabilidade:** Uma **vulnerabilidade** é uma fraqueza ou condição que pode ser explorada por uma ameaça para produzir um efeito indesejado.

- **Risco:** O **risco** surge da possibilidade de uma ameaça explorar uma vulnerabilidade e produzir consequências para um ativo. Em termos simples:



Fórmula Visual do Risco Cibernético

- **Ataque:** Um **ataque cibernético** ocorre quando uma ameaça utiliza uma técnica, ferramenta ou estratégia para explorar uma vulnerabilidade ou obter uma vantagem indevida. Um ataque pode ter diferentes objetivos, como:

  - obter credenciais;
  - acessar informações sem autorização;
  - instalar código malicioso;
  - alterar ou excluir dados;
  - interromper um serviço;
  - controlar um dispositivo;
  - monitorar atividades;

- **Comprometimento:** O **comprometimento** ocorre quando um ativo deixa de estar sob controle exclusivamente autorizado ou passa a apresentar alterações decorrentes de uma ação indevida.

- **Incidente de segurança:** Um **incidente de segurança** é um evento ou conjunto de eventos que compromete, ou pode comprometer, a segurança de informações, sistemas ou ativos institucionais. Um incidente pode envolver, por exemplo:

  - acesso não autorizado;
  - infecção por *malware*;
  - vazamento de informações;
  - roubo de credenciais;
  - indisponibilidade de sistemas;
  - alteração indevida de arquivos;
  - instalação não autorizada de software;
  - perda ou furto de dispositivo;
  - utilização indevida de uma conta institucional.

É importante destacar que **um incidente não precisa necessariamente resultar em grandes danos para ser relevante**. A identificação precoce de uma atividade suspeita pode permitir que o problema seja interrompido antes que produza consequências maiores.

IMPORTANTE

Um computador não precisa apresentar uma mensagem: "você foi invadido" para estar comprometido. Da mesma forma, uma mensagem suspeita não precisa causar um dano para representar um risco. Reconhecer os sinais antes que o problema se concretize é uma das funções mais importantes da segurança cibernética.



No ambiente institucional, a proteção dos ativos depende de uma combinação de tecnologia, processos e comportamento humano. Atualizações de segurança, autenticação adequada, controle de acesso, antivírus, firewall e mecanismos de monitoramento são importantes. Entretanto, esses controles precisam estar acompanhados de **atenção e comportamento seguro por parte dos usuários**.

1.2. MALWARE E CÓDIGOS MALICIOSOS

O termo ***malware*** é uma abreviação de *malicious software*, ou **software malicioso**. É utilizado para designar programas, códigos ou componentes desenvolvidos com a finalidade de executar ações não autorizadas ou prejudiciais em computadores, smartphones, servidores e outros dispositivos.

O *malware* pode ter objetivos muito diferentes. Alguns códigos procuram simplesmente causar danos ou interromper o funcionamento de um equipamento. Outros procuram permanecer ocultos, capturar informações, roubar credenciais, monitorar atividades, permitir acesso remoto ou transformar o dispositivo comprometido em parte de uma rede controlada por terceiros.

Essa diversidade é importante porque **nem todo *malware* se comporta da mesma maneira**: um *ransomware*, por exemplo, pode tornar arquivos inacessíveis. Um *spyware* pode

permanecer silenciosamente coletando informações. Um *keylogger* pode registrar aquilo que é digitado pelo usuário. Um RAT pode permitir que terceiros controlem remotamente o dispositivo. Um *worm* pode utilizar uma vulnerabilidade de rede para se propagar automaticamente.

Portanto, quando se afirma que determinado computador está “infectado por um vírus”, essa expressão nem sempre descreve tecnicamente o que está acontecendo. O código malicioso pode pertencer a outra categoria ou, inclusive, combinar características de diferentes tipos de *malware*.

INSIGHT DO PROFESSOR

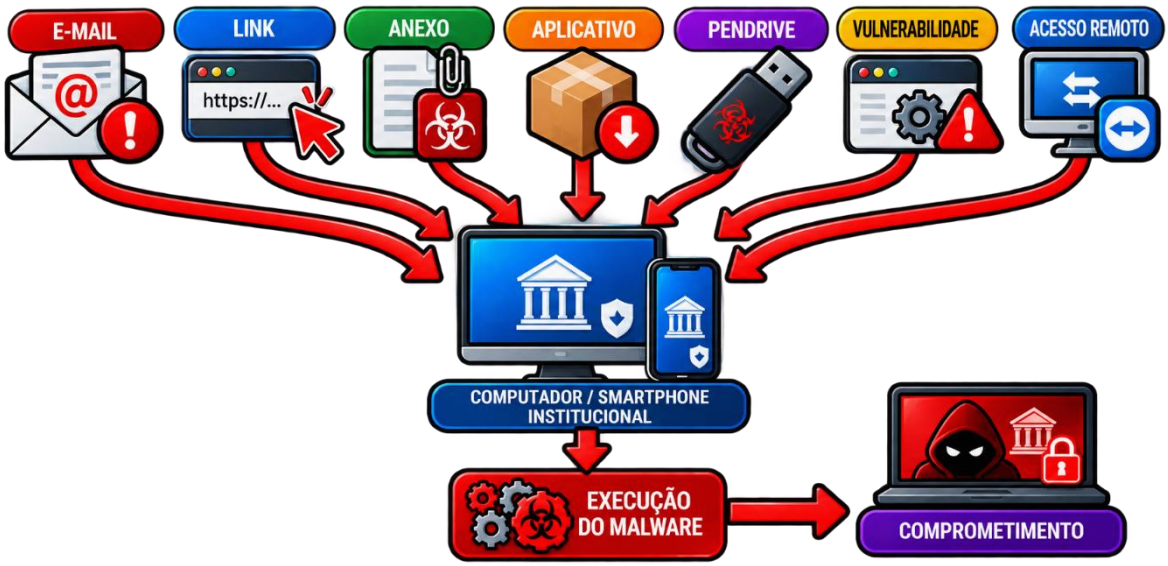
Malware não é um único tipo de ameaça. É uma categoria que reúne diferentes formas de código malicioso, com diferentes mecanismos de infecção, objetivos e consequências.



Existem diversas formas de um *malware* chegar a um computador ou *smartphone*. Entre elas estão:

- anexos maliciosos enviados por e-mail;
- links fraudulentos;
- programas obtidos de fontes não confiáveis;
- aplicativos maliciosos;
- arquivos aparentemente legítimos;
- páginas comprometidas;
- dispositivos removíveis;
- exploração de vulnerabilidades;
- credenciais comprometidas;
- ferramentas de acesso remoto utilizadas de maneira indevida.

Isso significa que o *malware* nem sempre precisa "invadir" diretamente um computador. Em muitos casos, **o próprio usuário participa involuntariamente da primeira etapa do comprometimento**, por exemplo, ao abrir um arquivo, instalar um aplicativo ou permitir uma determinada ação. Esse aspecto será retomado no tópico sobre engenharia social, mas é importante perceber desde já a relação:



Vetores de Infecção e Comprometimento Institucional

- **Vírus:** o **vírus de computador** é um tipo de *malware* capaz de se inserir ou se associar a outros arquivos ou programas e, a partir de sua execução, realizar ações maliciosas e eventualmente favorecer sua propagação.

  - modificar arquivos;
  - corromper dados;
  - prejudicar o funcionamento do sistema;
  - alterar configurações;
  - instalar outros componentes maliciosos;
  - tentar se espalhar para outros arquivos ou dispositivos.

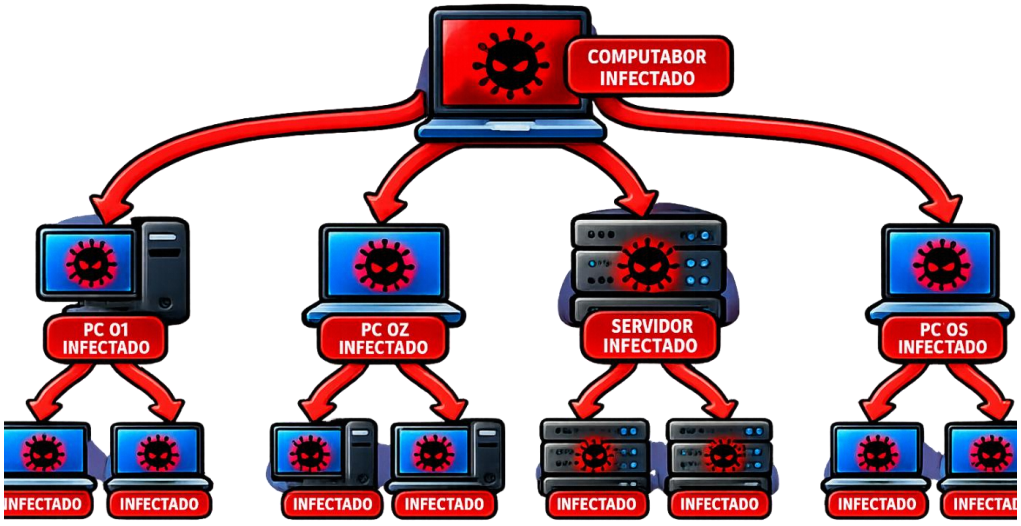
INSIGHT DO PROFESSOR



Quando alguém diz: "meu computador pegou um vírus", a pergunta tecnicamente mais importante não é apenas "qual vírus?", mas: "O que esse código está fazendo no dispositivo?" Dependendo da resposta a classificação é de outro *malware,* que não um vírus!

- **Worms: quando o malware se propaga sozinho.** Os ***worms***, ou vermes de computador, apresentam uma característica particularmente importante: podem se **propagar automaticamente entre sistemas**, explorando vulnerabilidades ou outros mecanismos de comunicação.

É justamente esse comportamento que tornou o ***WannaCry***, em 2017, um dos exemplos mais conhecidos de propagação rápida de *ransomware*. O código explorava uma vulnerabilidade relacionada ao serviço SMBv1 do *Windows* e possuía um componente de *worm* que permitia tentar comprometer outros sistemas. A CISA **(Cybersecurity and Infrastructure Security Agency)** registrou que a campanha atingiu centenas de milhares de sistemas em mais de 150 países.



Propagação de Worm na Rede

O caso WannaCry: O *WannaCry* é particularmente interessante como exemplo, porque demonstra como **uma vulnerabilidade técnica aparentemente localizada pode produzir consequências em escala global**.



Wanna Cry em ação em 2017

O episódio também demonstra a importância de uma medida que, à primeira vista, parece simples: **manter sistemas e aplicações atualizados.** Uma vulnerabilidade conhecida e já corrigida pode continuar representando um risco quando dispositivos permanecem sem atualização.

- **Trojan: o malware que se apresenta como algo legítimo:** O termo **Trojan**, ou cavalo de Troia, é utilizado para designar um *malware* que procura se apresentar como um arquivo, programa ou recurso aparentemente legítimo, levando o usuário ou outro processo a executá-lo.

“Documento_Oficial.pdf” ou **“Atualizacao_Seguranca.exe”**

Depois de executado, entretanto, o código pode realizar outras ações. O Trojan pode ser utilizado para:

- instalar outros *malwares*;
- capturar informações;
- estabelecer persistência;
- roubar credenciais;
- permitir acesso remoto;
- preparar o equipamento para uma segunda etapa do ataque.

Essa última característica é especialmente importante. **O primeiro *malware* que chega ao computador nem sempre é aquele que causa o dano final.** Ele pode funcionar como uma espécie de **porta de entrada**, permitindo que outros componentes sejam posteriormente instalados.



Cadeia de Infecção por Trojan

2. LEGISLAÇÃO E CRIMES DIGITAIS

Crimes digitais são condutas ilícitas que utilizam computadores, dispositivos, programas ou redes como **meio ou finalidade para a prática do crime**. O termo pode aparecer também como crime cibernético, crime informático, crime eletrônico ou crime digital. A tecnologia pode assumir diferentes papéis:

- **Meio:** utilizada para praticar o crime.
- **Alvo:** o próprio sistema ou dispositivo é atacado.
- **Ambiente:** o crime ocorre em plataformas digitais.

2.1. Principais Crimes Digitais

- **Invasão de dispositivo informático:**

Consiste no acesso não autorizado a dispositivo informático, como computador ou smartphone, com finalidade criminosa. **Exemplo:** invasão de um computador para obter arquivos ou informações pessoais. **Legislação:** art. 154-A do Código Penal. A Lei nº 12.737/2012 ficou conhecida como **Lei Carolina Dieckmann** e posteriormente o dispositivo foi alterado pela Lei nº 14.155/2021

- **Fraude eletrônica**

É a utilização de meios eletrônicos para obter vantagem ilícita mediante fraude ou indução da vítima ao erro. **Exemplos:**

- phishing;
- páginas falsas;
- golpes bancários;

- falsos atendentes;
- comprometimento de contas.

Legislação: art. 171 do Código Penal, com alterações da Lei nº 14.155/2021

- ### Interrupção de serviço

Ataques podem provocar a interrupção ou perturbação de serviços informáticos, telemáticos ou de utilidade pública. **Exemplo:** ataque **DDoS**, no qual diversos dispositivos enviam grande quantidade de requisições para tornar um serviço indisponível. **Legislação:** art. 266 do Código Penal.

- ### Crimes contra a honra

A utilização da Internet não elimina a responsabilidade por ofensas praticadas contra outras pessoas. Os principais crimes são:

- **Calúnia:** atribuir falsamente a alguém um crime.
- **Difamação:** atribuir fato ofensivo à reputação.
- **Injúria:** ofender a dignidade ou o decoro.

- ### 2.6 Perfis falsos

A criação e utilização de identidade falsa na Internet pode, dependendo do caso concreto, caracterizar crimes como falsidade ideológica. **Legislação relacionada:** art. 299 do Código Penal.

- ## Fake News

Fake news são informações falsas ou fabricadas divulgadas com o objetivo de enganar ou manipular o público. **Importante:** a expressão "fake news" não corresponde, por si só, a um crime específico geral. A conduta pode estar relacionada a outros crimes, dependendo do conteúdo e da finalidade

- ## Cyberbullying e crimes de ódio

A Internet pode ser utilizada para ameaças, perseguições, humilhações e outras formas de violência. A **Lei nº 14.811/2024** trouxe alterações relevantes, incluindo a previsão relacionada ao **cyberbullying**.

- ## Material de Abuso Sexual Infantil — CSAM

CSAM (*Child Sexual Abuse Material*) refere-se a material digital relacionado ao abuso sexual de crianças e adolescentes. Entre as condutas relacionadas estão:

- produção;
- compartilhamento;
- armazenamento.

- ## Divulgação de imagens íntimas

A divulgação não autorizada de imagens ou vídeos íntimos pode configurar crime. **Art. 218-C do Código Penal:** relacionado à divulgação de cena de sexo, nudez ou pornografia sem consentimento. Também existe o **art. 216-B**, relacionado ao registro não autorizado de conteúdo íntimo.